Enterprise Information Security Policy

1. Purpose and Scope

This document establishes mandatory information security controls for enterprise generative AI, cloud workloads, and data governance. All full-time employees, contractors, and third-party vendors must strictly adhere to these policies.

Compliance audits are conducted quarterly by the Information Security Committee. Non-compliance may lead to access revocation and disciplinary action.

2. Data Classification Levels

Organizational data is categorized into four strict tiers:

Tier 1 - Public: Marketing brochures, published documentation, public repository code.

Tier 2 - Internal: Internal memos, company-wide announcements, standard org charts.

Tier 3 - Confidential: Customer personally identifiable information (PII), proprietary algorithms, financial ledgers, and trade secrets.

Tier 4 - Restricted: Production cryptographic root keys, PCI DSS cardholder data, executive board minutes, and unreleased M&A; agreements.

3. Authentication and Credential Management

All internal user accounts require hardware-backed FIDO2 multi-factor authentication (MFA). Single-factor SMS codes are strictly forbidden for administrative systems.

Password Rotation Policy: Passwords must be a minimum of 16 characters in length, containing uppercase letters, lowercase letters, numbers, and symbols. Passwords must be rotated every 90 days. Account lockouts trigger automatically after 5 consecutive failed login attempts.

4. Acceptable Use of Generative AI Models

Employees are prohibited from uploading Tier 3 (Confidential) or Tier 4 (Restricted) data into public AI services such as commercial chatbots without signed enterprise business associate agreements.

Enterprise Knowledge Copilot and internal model endpoints operate under private tenant boundary isolation where prompt inputs and retrieved context are never used for model re-training.

5. Security Incident Reporting and SLAs

Any suspected credential breach, unauthorized data exfiltration, or abnormal access spike must be reported to security-ops@enterprise.internal within 15 minutes of detection.

Critical Sev-1 security incidents require an emergency containment team assembly within 30 minutes, with executive status updates broadcasted every 60 minutes until full mitigation.